VERIFIKACIJA I VALIDACIJA SOFTVERA

IZVJEŠTAJ O INSPEKCIJI KODA

BentoLab

Inspektovani projekat / Grupa1 - Tim1

Članovi tima

Sunita Tahirović
Rasim Ćesko
Mehmed Šišić
Hana Hodžić

PREDMET
Verifikacija i validacija softvera

PROJEKTNI ZADATAK
I dio (Task 1)

1 Opseg i postupak

- Inspektovani projekat: BentoLab (tim Grupa1-Tim1), grana Inspekcija-koda.
- Veličina koda: oko 5.500 linija C# i Razor koda bez migracija (Controllers 1.669, Models 255, Views 3.510, Program.cs 56).
- Detaljno pregledano: Controllers, Models, Program.cs, appsettings.json i csproj (oko 2.000 linija). Views su većinom generisani CRUD pa su pregledani uzorkom. Migracije su izuzete jer su generisan kod.
- Ozbiljnost je određena skalom iz predavanja 2: 5 kritično, 4 visoko, 3 srednje, 2 nisko, 1 minorno.
- Nalazi su prijavljeni kao komentari na kod i issue kartice. Svaki sadrži ozbiljnost i stavku check liste.

2 Rezultati inspekcije

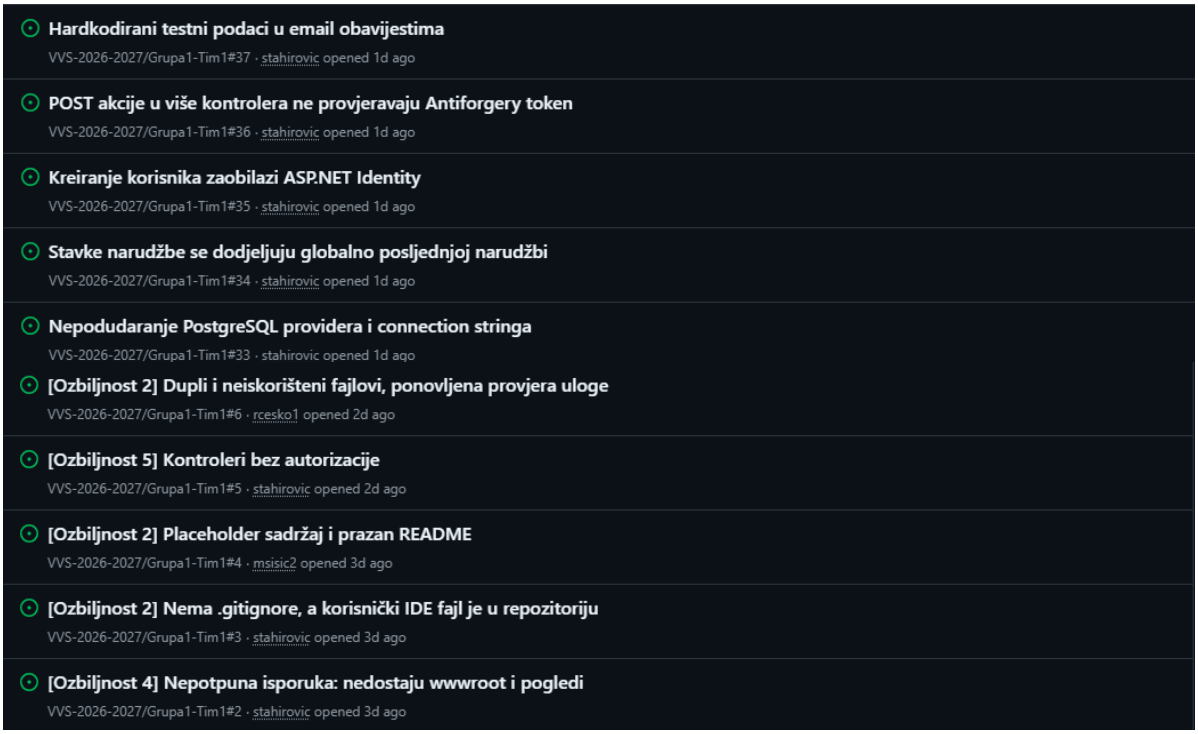
Ukupno je prijavljeno 30 nalaza: 20 komentara na kod i 10 issue kartica.

Ozbiljnost	Broj nalaza	Nalazi
5 kritično	4	N5, N7, N15, N20
4 visoko	9	N9, N10, N11, N12, N13, N14, N16, N21, N22
3 srednje	8	N1, N2, N8, N23, N24, N25, N27, N30
2 nisko	7	N3, N6, N17, N18, N19, N28, N29
1 minorno	2	N4, N26

ID	Lokacija	Nalaz	Oz.	Stavka check liste	Recenzent
N1	`Views/Shared/_LoginPartial.cshtml:19`	Odjava šalje GET bez antiforgery tokena (CSRF)	3	Sigurnosna: Kontrola pristupa	Sunita
N2	`Program.cs:16`	Potvrda naloga mailom je uključena, a servis za slanje nije povezan	3	Opšta: Defanzivno programiranje	Sunita
N3	`appsettings.json:11`	AllowedHosts je *	2	Sigurnosna: konfiguracija	Sunita
N4	`Views/Shared/Error.cshtml:16`	Razvojni tekst prikazan krajnjem korisniku	1	Sigurnosna: Upravljanje greškama	Rasim
N5	`AdminNarudzbeController.cs:12`	Nema autorizacije, svako može mijenjati status narudžbi	5	Sigurnosna: Kontrola pristupa	Rasim
N6	`AdminNarudzbeController.cs:56`	Enum.TryParse prihvata nepostojeće statuse	2	Sigurnosna: Validacija unosa	Sunita

ID	Lokacija	Nalaz	Oz.	Stavka check liste	Recenzent
N7	`Korisniks Controller.cs:57`	Bind uključuje Uloga bez autorizacije (over-posting)	5	Sigurnosna: Kontrola pristupa	Sunita
N8	`HomeController.cs:55`	POST akcije bez ValidateAntiForgeryToken	3	Sigurnosna: Kontrola pristupa	Mehmed
N9	`Tortas Controller.cs:104`	Cijenu torte određuje klijent	4	Sigurnosna: Validacija unosa	Mehmed
N10	`Narudzbas Controller.cs:77`	Narudžba se pripisuje pogrešnom korisniku	4	Opšta: Defanzivno programiranje	Sunita
N11	`Korpas Controller.cs:94`	Podaci o dostavi se ne spremaju, nema autorizacije	4	Opšta: Defanzivno programiranje	Sunita
N12	`EmailService.cs:89`	SMTP kredencijali u izvornom kodu	4	Sigurnosna: Upravljanje tajnama	Hana
N13	`Kamera Controller.cs:35`	Slanje fajlova bez prijave i bez provjere sadržaja	4	Sigurnosna: Validacija unosa	Hana
N14	`Models/Korisnik.cs:14`	NotMapped polja se koriste u upitima, Lozinka u modelu	4	Opšta: Struktura	Sunita
N15	Issue 1	Kontroleri bez `[Authorize]`	5	Sigurnosna: Kontrola pristupa	Sunita
N16	Issue 2	Nedostaju wwwroot i pogledi	4	Opšta: Struktura	Sunita
N17	Issue 4	Dupli i neiskorišteni fajlovi	2	Opšta: Struktura	Rasim
N18	Issue 5	Nema .gitignore	2	Opšta: Struktura	Sunita
N19	Issue 6	README je prazan	2	Opšta: Struktura	Mehmed
N20	Issue 7	PostgreSQL provider ne odgovara SQL Server connection stringu (Program.cs:11–13, 50–54; appsettings.json:2–4)	5	Opšta: Defanzivno programiranje / Konfiguracija	Sunita
N21	Issue 8	Stavke narudžbe se dodjeljuju posljednjoj narudžbi u bazi (StavkaNarudzbesController.cs: 56–63)	4	Opšta: Defanzivno programiranje / Sigurnosna: Kontrola pristupa	Sunita
N22	Issue 9	Kreiranje korisnika zaobilazi ASP.NET Identity (KorisniksController.cs:57–62; Models/Korisnik.cs:13–18)	4	Sigurnosna: Upravljanje identitetom / Kontrola pristupa	Sunita
N23	Issue 10	POST akcije bez ValidateAntiForgeryToken u više kontrolera (TortasController.cs i KorpasController.cs; proširuje N8)	3	Sigurnosna: Kontrola pristupa	Sunita

ID	Lokacija	Nalaz	Oz.	Stavka check liste	Recenzent
N24	Issue 11	Hardkodirani testni email i broj narudžbe u obavijestima (KameraController.cs:59–64; KorpasController.cs:109–112)	3	Opšta: Defanzivno programiranje	Sunita
N25	`HomeController.cs:69`	Blokiranje korisnika ne poništava postojeću sesiju (nedostaje UpdateSecurityStampAsync)	3	Sigurnosna: Kontrola pristupa	Rasim
N26	`HomeController.cs:42`	Sinhroni ToList() nad svim korisnicima, bez straničenja	1	Opšta: Struktura	Rasim
N27	`NarudzbasController.cs:118`	Korisniku se vraćaju ex.Message i InnerException	3	Sigurnosna: Upravljanje greškama	Mehmed
N28	`TortasController.cs:65`	Cijene i koeficijent upisani u kod, novac u tipu double	2	Opšta: Varijable i aritmetika	Mehmed
N29	`EmailService.cs:53`	Goli catch guta greške bez zapisa u log	2	Sigurnosna: Upravljanje greškama	Hana
N30	`BentoLab.csproj:8`	NuGetAudit isključen, ranjivi paketi se ne prijavljuju	3	Sigurnosna: Sigurnost zavisnosti	Hana

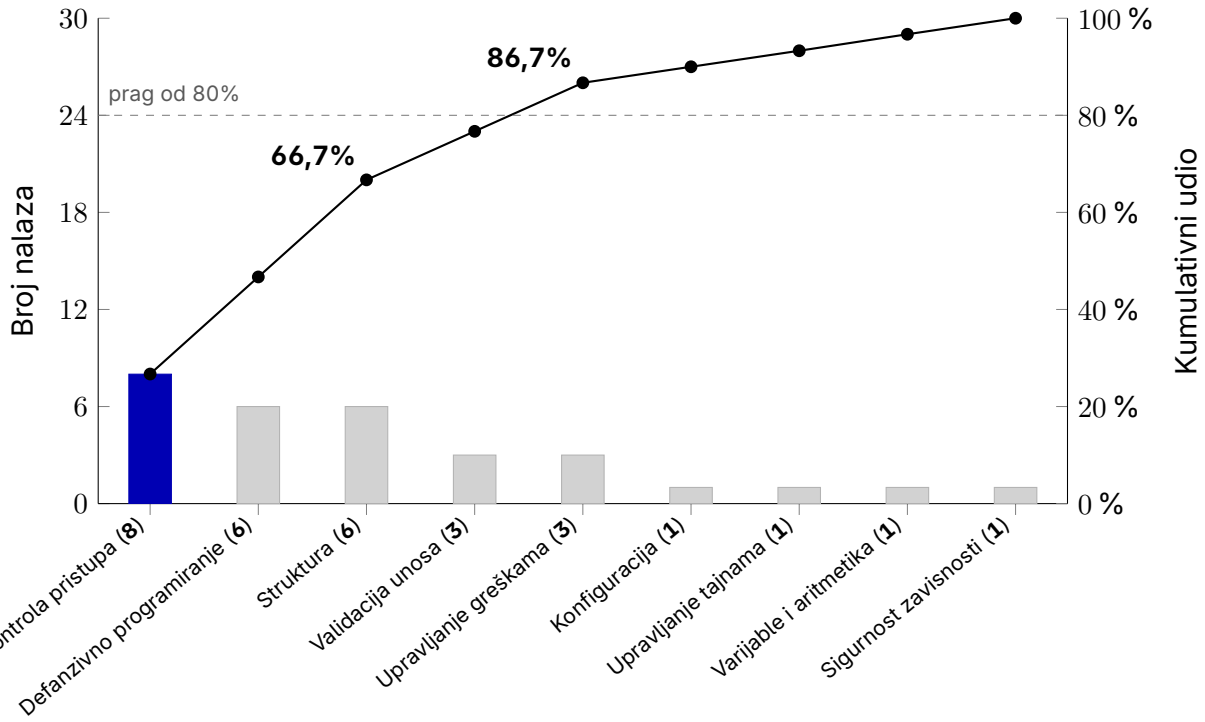


Slika 1: Pokriveni issues

3 Pareto analiza defekata

Tip defekta je stavka check liste u koju nalaz spada. Svaki prijavljeni nalaz je dodijeljen jednoj stavci. Nalazi s dvije navedene stavke (N20, N21) dodijeljeni su prvoj navedenoj, a N22 je dodijeljen tipu Kontrola pristupa jer upravljanje identitetom nije zasebna stavka check liste. Brojevi u Pareto analizi predstavljaju evidentirane komentare i Issue kartice; N5 i N7 su konkretni primjeri šireg problema grupisanog u N15, pa se njihov tematski preklop mora imati u vidu pri tumačenju rezultata.

Tip defekta	Broj	Udio	Kumulativno
Kontrola pristupa	8	26,7%	26,7%
Defanzivno programiranje	6	20,0%	46,7%
Struktura	6	20,0%	66,7%
Validacija unosa	3	10,0%	76,7%
Upravljanje greškama	3	10,0%	86,7%
Konfiguracija	1	3,3%	90,0%
Upravljanje tajnama	1	3,3%	93,3%
Varijable i aritmetika	1	3,3%	96,7%
Sigurnost zavisnosti	1	3,3%	100%



Slika 2: Kontrola pristupa je najčešći tip defekta (8 od 30 nalaza), a prag od 80% se dostiže sa pet tipova. Stupci: broj nalaza (lijeva osa), linija: kumulativni udio (desna osa). Izvor: tabela nalaza N1–N30 ovog izvještaja, tip defekta = stavka check liste.

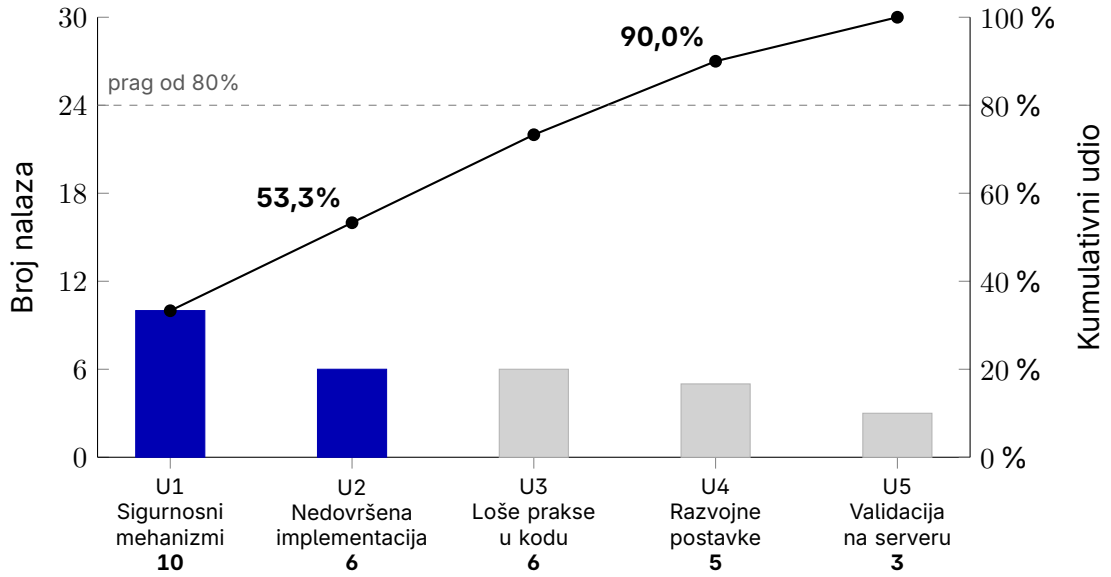
Kontrola pristupa je najčešći tip defekta sa 26,7% nalaza. Zajedno sa Defanzivnim programiranjem i Strukturom čini 66,7%, a prag od 80% se dostiže tek sa pet tipova. Tri od

četiri nalaza ozbiljnosti 5 (N5, N7, N15) pripadaju tipu Kontrola pristupa, pa je on ujedno i tip s najvećim uticajem. Novi nalazi su uveli i dva nova tipa, Varijable i aritmetika (N28) te Sigurnost zavisnosti (N30).

4 Pareto analiza uzroka

Za svaki nalaz je određen osnovni uzrok. Dodjela uzroka je procjena tima, a ne mjerenje.

Uzrok	Nalazi	Broj	Udio	Kumulativno
U1: Nedovoljna primjena sigurnosnih mehanizama (autorizacija, CSRF, tajne, sesije)	N1, N5, N7, N8, N12, N15, N21, N22, N23, N25	10	33,3%	33,3%
U2: Nedovršena implementacija i ostavljen privremeni kod	N2, N10, N11, N16, N19, N24	6	20,0%	53,3%
U3: Loše prakse u kodu i repozitoriju (organizacija, rukovanje greškama)	N14, N17, N18, N26, N28, N29	6	20,0%	73,3%
U4: Razvojne postavke i ispisi ostavljeni u kodu i konfiguraciji	N3, N4, N20, N27, N30	5	16,7%	90,0%
U5: Povjerenje podacima s klijenta, validacija na serveru nedostaje	N6, N9, N13	3	10,0%	100%



Slika 3: Dva uzroka čine 53,3% nalaza. Stupci: broj nalaza (lijeva osa), linija: kumulativni udio (desna osa). Izvor: tabela nalaza N1–N30 ovog izvještaja, dodjela uzroka je procjena tima.

Dva najčešća uzroka (U1 i U2) čine 53,3% nalaza, a tri uzroka 73,3%. Najvažniji uzrok je izostanak sigurnosnih mehanizama, a odmah iza njega, sa po 6 nalaza, dijele se nedovršen razvoj (U2) i loše prakse u kodu (U3). Ispravljanje uzroka U1 i U2 uklonilo bi više od polovine nalaza.

5 Statička analiza (Roslyn Analyzers)

Analiza je provedena nad istim kodom komandama:

- `dotnet build (AnalysisLevel=latest-all, EnforceCodeStyleInBuild=true)`,
- `dotnet format style`,
- `dotnet package list --vulnerable --include-transitive`.

Build je uspio bez grešaka. Pronađeno 247 upozorenja.

Oznaka	Broj	Značenje	Procjena
CA2007	69	ConfigureAwait	Šum, nije relevantno za ASP.NET Core
CA5395	45	Nedostaje HTTP verb atribut na akciji	Djelimično relevantno, potvrditi
CA1515	33	Javni tipovi mogu biti internal	Stilska preporuka
CS8618	20	Neinicijalizovana svojstva (nullable)	Stvaran nedostatak, nizak uticaj
CA1062	18	Argumenti javnih metoda nisu provjereni	Dio je u generisanim migracijama
CS8600	11	Moguća null dodjela	Stvaran nedostatak, nizak uticaj
CA5391	9	POST akcije bez antiforgery tokena	Potvrđuje nalaze N8 i N23

Dodatna provjera stila (dotnet format style) dala je 32 informativna upozorenja: IDE0290 (11), IDE0019 (7), IDE0060 (5), IDE0017 (4), IDE0305 (2), IDE0028 (2), IDE0090 (1).

Provjera ranjivih paketa našla je četiri tranzitivna paketa: SQLitePCLRaw.lib.e_sqlite3 2.1.11 (visoka ozbiljnost), System.Security.Cryptography.Pkcs 9.0.4 (visoka i srednja), te NuGet.Packaging i NuGet.Protocol 6.12.1 (niska). Ti paketi se ne prijavljuju pri buildu jer je u projektu isključen NuGetAudit (N30).

Poređenje s ručnom inspekcijom: alat je potvrdio nalaze o POST akcijama bez tokena (N8, N23; CA5391 prijavljuje 9 upozorenja) i našao nalaze koje ručni pregled nije obuhvatio, a to su nullable upozorenja i konkretni ranjivi paketi, dok je ručna inspekcija otkrila da je provjera ranjivosti u projektu isključena (N30). Ručna inspekcija je našla i ono što alat ne može: nedostatak autorizacije, hardkodirane kredencijale, cijenu koju određuje klijent i nedovršenu funkcionalnost. Sva upozorenja alata nisu stvarne greške, jer je dio njih stilska preporuka ili šum (npr. CA2007), pa ih je trebalo procijeniti ručno.

6 Zaključak i preporuke

1. Dodati autorizaciju (`[Authorize]` i provjeru uloge) na sve kontrolere osim javnih (N5, N7, N15), provjeriti vlasništvo nad narudžbama (N21), kreirati korisnike preko `UserManager` (N22) i pri blokiranju korisnika poništiti njegovu sesiju (N25). To je najozbiljniji nalaz i najčešći tip defekta.
2. Svu logiku koja utiče na novac i podatke izvršavati na serveru: cijenu računati na serveru, validirati unos i dodati ValidateAntiForgeryToken na POST akcije (N6, N8, N9, N13, N23). Cijene držati u konstantama ili bazi, a novac u tipu decimal (N28).

3. Dovršiti započete funkcije (potvrda naloga mailom, spremanje podataka o dostavi, wwwroot i pogledi) i izbaciti privremeni kod (N2, N10, N11, N16, N24). Uskladiti konfiguraciju baze s providerom (N20). Kredencijale prebaciti u user-secrets ili varijable okruženja (N12). Korisniku ne prikazivati interne poruke grešaka, a greške zapisivati kroz ILogger umjesto da se guše (N27, N29).

4. Dodati .gitignore, README i ukloniti dupli kod (N17, N18, N19), uključiti NuGetAudit i ažurirati ranjive pakete (N30).